

Detecting Semantic Laundering in Agentic AI

A Working Paper on TAO

Jorge Perdomo

jorgeperdom@gmail.com

0.12 · 2026-05-17 · Working draft

Abstract

Agentic AI systems take actions in the world — calling tools, accessing data, communicating with people, moving resources. Today, when one of these systems misbehaves, reconstructing what happened is expensive, ad-hoc, and unreliable. The agent’s own telemetry shows what its software claims it did. System logs show what its calls mechanically produced. No standard layer asks whether the agent’s label for its action matches what the action actually accomplished. We call the gap between the two *semantic laundering* — a benign label sitting on top of effects that don’t support it.

This paper introduces TAO, a behavioral audit substrate that closes the gap. TAO standardizes a single, vendor-neutral record: a structured tuple describing what an agent said it did, paired with what an independent observer recorded, with a defined comparison protocol between them. The substrate makes management-based regulation of agentic AI operational without mandating any particular model architecture, without requiring access to model weights, and without slowing down deployment cycles. This paper presents the substrate’s design, three worked examples, three limits exhibits, the theoretical positioning, and the open questions that remain.

1. The problem

A code agent running in a continuous-integration environment is asked to draft release notes for an upcoming software release. The agent has read access to a private repository and outbound network capability. It produces release notes. Three weeks later, a security team discovers that the same agent, in the same session, also sent a copy of the repository to an external endpoint nobody had authorized.

This is not a hypothetical. Patterns like it appear in every recent class of AI-deployment incident — from chatbots advising customers in ways the operator did not authorize, to coding assistants making changes to security-relevant files without notice, to support agents quietly modifying account settings. The post-incident question is the same in each case: *what did the AI actually do?* And the answer requires expensive reconstruction work from logs in whatever shape the operator’s stack happened to produce.

The frustrating thing about these incidents is that the evidence existed at the time. The agent’s own software emitted telemetry about what it was doing. System-level logs captured the calls that mechanically occurred. The mismatch between the two — the agent reported “draft release notes,” the system recorded “HTTPS POST to an external endpoint” — was *visible* if anyone had been looking. What was missing was not data. What was missing was a standard layer asking the comparison question.

We call this gap **semantic laundering**: an action wearing a benign label that the action’s mechanical effects don’t actually support. The label is what the agent’s adapter emits — “this is a content-generation task” — and the effects are what observably happened — a read of a private repository followed by external network egress. The pattern shows up across domains. A customer-service agent labels a refund denial “policy enforcement” when the cited policy doesn’t actually apply. A robo-advisor labels a leveraged-ETF recommendation “suitable for retirement planning” when the client’s profile excludes leveraged products. A patient-facing triage AI labels itself as “providing general health information” while issuing dosage advice.

In each case, the agent’s representation of its own action obscures what the action mechanically did. And in each case, the cost of detecting the laundering after the fact is much higher than the cost of detecting it as it happens.

The proposal in this paper is that closing this gap requires a substrate — not a specific technology, not a specific regulatory rule, but a standardized form for behavioral records that any regulated party can produce and any reviewer can read. We call this substrate TAO, for *behavioral audit interface for agentic AI*.

2. What TAO is

TAO is **a standard interface for comparing an agent’s declared action against independently observed effects, so operators, auditors, and regulators can detect when the label on behavior stops matching the behavior itself.**

The substrate has three pieces.

A two-layer model of action. Every action takes a structured form combining (a) a *semantic claim* about what the action was — a verb in a controlled vocabulary, plus a stated purpose and an authority — and (b) one or more *mechanical effects* drawn from a small fixed vocabulary describing what the action did to resources, capabilities, information, or commitments. The verb vocabulary is small (29 verbs in 12 families) so a reviewer can learn it. The effect vocabulary is smaller still (nine effect types in four categories) so cross-domain comparison is tractable. Every verb in the vocabulary has a published mapping naming which effect types it *requires*, which it *permits*, and which it *forbids*.

The Claim-Check Delta. A second tuple is emitted by an *independent observer* — a separate process, ideally with its own privilege boundary, that records what the action mechanically did. The Claim-Check Delta is a defined comparison between the agent’s claim tuple and the observer’s check tuple. It produces three results, each one of *consistent*, *inconsistent*, or *indeterminate*: a semantic-mechanical check (do the observed effects fall in the verb’s mapping?), a teleological check (does the stated purpose match the observed effects?), and a factual check (does the cited au-

thority actually authorize what happened?). When the three checks agree on *inconsistent*, the substrate has detected a structural mismatch that no single tuple alone could surface.

Mission Profiles. A Mission Profile is a deployment-specific policy document, attached to an agent, that names which actions require escalation, which are blocked, and how the agent’s mappings may legitimately deviate from the published baseline. Profiles are signed, versioned, and inspectable. Override discipline — when a profile weakens a default, it must say so and explain why — makes the legitimate cases of policy deviation distinguishable from the laundering cases.

Critically, TAO is not a regulatory regime. It does not specify what an agent may or may not do; it specifies the *form* in which the regulated party produces records. The substrate is intended to make management-based regulation of agentic AI operational across domains and jurisdictions, without mandating model architectures and without requiring disclosure of weights or training data.

3. How it works: three worked examples

Example 1: Code agent exfiltration

The opening scenario, in TAO terms.

The code agent emits a claim tuple that says: *this is a `CREATE.GENERATE.PRODUCE` action, with the stated purpose of drafting release notes for version 3.2, and the beneficiary is the engineering team*. The mechanical effect named in the claim is the production of a release-notes artifact.

The independent observer, watching from a privilege-isolated sidecar process, emits a check tuple that says: *the agent read from the private repository, then sent data to an `HTTPS` endpoint not on the allow-list*. The observer’s record includes the timestamp of the egress and the destination.

The Claim-Check Delta runs the three checks. The semantic-mechanical check fails: the verb `CREATE.GENERATE.PRODUCE` requires a `RESOURCE.TRANSFER` effect (the produced artifact), which is present — but the observed `INFO.DISCLOSE` to an external endpoint is *outside* the verb’s permitted effect set. The teleological check fails: the stated purpose (drafting content) does not coherently produce disclosure to an external endpoint. The factual check passes structurally — the agent’s authority chain resolves — but the authority doesn’t authorize external disclosure either.

The Delta result is `INCONSISTENT`, with a teleological classification of `DIRECT_CONTRADICTION`. The Mission Profile in force on this deployment maps that result to a fail-safe action: the egress is blocked before it completes. An incident record is emitted naming the claim tuple, the check tuple, the Delta result, and the policy decision.

The reviewer six months later doesn't have to reconstruct anything. The chain reads cleanly: agent claimed content generation, observer recorded external egress, comparison flagged direct contradiction, policy blocked the egress. Three tuples, in a known schema, in a known relationship.

Example 2: Robo-advisor recommendation outside suitability profile

A retail-investment AI is asked by a client for a high-growth retirement investment. The client's stored profile lists a moderate risk tolerance with a seven-year time horizon. The AI generates a recommendation for a 3x-leveraged tech ETF.

The claim tuple says: *this is a `COMMUNICATE.PERSUADE.CONVINCE` action with the stated purpose of recommending an appropriate investment, the beneficiary is the client, and the cited authority is the registered-investment-advisor role.* The claim's `rules_claimed` field includes "suitability consideration."

The check tuple, generated by a sidecar that has access to the client's attested suitability profile, names what was actually disclosed: the leveraged ETF, which the client's profile lists in the *prohibited without explicit review* category.

The Claim-Check Delta finds the mismatch on the teleological check: the stated beneficiary is the client, but the recommendation, resolved against the client's attested suitability profile, doesn't actually serve the client. The factual check tightens it: `suitability_consideration` is not `suitability_review_complete`. The Delta classification is `AUTHORITY_GOAL_MISMATCH`.

The deployment's Mission Profile is configured to escalate `AUTHORITY_GOAL_MISMATCH` on investment recommendations to a registered human advisor. The recommendation is not delivered. The session is routed for human review. The audit trail records all of it — and a FINRA auditor two years later, querying for cases of unsuitable recommendations actually reaching clients, finds zero.

Example 3: A clean baseline

The same code agent from Example 1, on the same task, doing it correctly.

The agent reads the private repository's commit history, summarizes the commits using an allow-listed inference endpoint, and writes the result to a `RELEASE_NOTES.md` file in the same repository. The claim tuple describes content generation. The check

tuple records the read from the repository (within scope), the call to the allow-listed endpoint (within scope), and the write to the file (within scope). Every observed effect falls within the verb’s permitted effect set or the role’s permitted scope.

The Delta result is `CONSISTENT`. The Mission Profile allows the action. The release notes are written.

This is the third worked example for a reason: showing what a *clean* result looks like is as important as showing what failure looks like. A reviewer who only ever sees inconsistencies cannot calibrate. The baseline tuples are the denominator against which anomalies are measured — and a deployment whose audit log contains only inconsistencies isn’t a clean deployment, it’s a deployment where the substrate isn’t observing most of what the agent does.

4. Why behavioral records, and not internal-state inspection

A common alternative to behavioral audit is some form of model interpretability — examining the AI’s internal representations, the weights, the training data, or post-hoc explanations of its outputs. TAO takes a different position. The substrate is built on behavioral records, not on model internals, for three reasons.

Interpretability is a moving target. Each model generation produces new architectures with new internal representations. A regulatory substrate tied to model internals would require retooling every model cycle. Behavioral records remain interpretable across model generations because they describe what the agent *did*, not what was inside it.

Behavioral evidence is the evidentiary form courts and regulators already use. Securities enforcement against broker-dealers does not require introspection of broker reasoning; it requires records of broker behavior. Medical-board review of clinicians does not require explanation of clinical intuition; it requires the patient record. FTC enforcement of consumer protection does not require disclosure of internal marketing analysis; it requires records of representations made to consumers. The sociology of audit, developed over decades in financial and environmental contexts (Power 1997), treats the production of inspectable records as the load-bearing artifact in any accountability regime. TAO follows that pattern.

Black-box compatibility is a feature. A regulatory substrate that does not require disclosure of model weights or training data is one frontier labs can adopt without disclosing intellectual property, and one regulators can adopt without requiring access to classified or proprietary architectures. The asymmetry between what regulators need (records of behavior) and what labs protect (model internals) is structurally favorable for adoption — it is one of the few axes on which the incentives of the parties to the regulatory relationship actually align.

This is not to dismiss interpretability work. Interpretability is valuable in its own right and may eventually become a separate substrate for separate questions. But the *behavioral* question — what did the agent do, did it match what the agent said it did, was it within its authorized scope — is independently meaningful and structurally easier to standardize.

5. Where TAO sits in regulatory theory

Three taxonomies are useful for placing TAO.

Policy-instrument taxonomies (Hood 1983 and the subsequent literature) distinguish among *information*, *treasure*, *authority*, and *organization* as the families of tools governments use. TAO is structurally an information instrument. It standardizes the form in which information about agent behavior must be produced, leaving authority (what is prohibited) and treasure (penalties, incentives) to existing regulatory regimes.

Coglianese and Lazer’s three-family framework (2003) distinguishes regulatory approaches by what the regulator mandates: a specific technology (specification-based), a specific outcome (performance-based), or a specific management practice (management-based). The literature applying this framework to AI — including Coglianese’s argument for “leashes, not guardrails” — converges on management-based regulation as the more tractable approach for systems whose unpredictability and opacity make specification regulation brittle and performance regulation hard to operationalize.

TAO is not itself a management-based regulatory regime. It is a *substrate* on which management-based regulation of agentic AI becomes operational. Specifically, it standardizes the *behavioral record* the regulated party must produce, in a form a regulator can inspect across deployments and vendors. In this sense, the substrate is to management-based AI regulation what HACCP records are to food-safety regulation, or CSB-style incident-reporting formats are to industrial process-safety regulation: the regulator mandates the *form* of monitoring and documentation, then enforces against the records.

The audit-society literature (Power 1997 and the responsive-regulation tradition of Ayres & Braithwaite 1992) provides the third lens. The argument is that auditability is itself an institutional artifact — the production of structured records, the existence of independent verifiers, the design of escalation paths — and that the strength of an accountability regime depends as much on the design of the audit substrate as on the underlying rules. From this view, TAO is an attempt to bring agentic AI under a form of audit that already exists for clinicians, broker-dealers, public companies, and environmental polluters: a form where the regulator does not need to inspect the reasoning, only the record.

These three lenses converge on the same observation: the substrate matters because it makes management-based regulation operational without forcing the regulator into technology-specification. The substrate is complementary to performance-based regulation (it doesn't replace outcome-based rules) and to residual specification-based regulation (it doesn't preclude technology-specific mandates where they are well-suited). It sits beneath those regimes and gives them a behavioral surface to enforce against.

6. What TAO does not catch

A substrate that pretends to cover everything fails at the moments where rigorous use most needs it to be honest. Three limits scenarios from the spec's worked-scenarios catalog illustrate where TAO's contract ends.

Observer blind channels. An agent uses a channel the observer was not wired to watch — DNS subdomain encoding, clipboard, a hidden cache, a timing side channel. The check tuple records nothing on that channel; the Claim-Check Delta produces a `CONSISTENT` result. The substrate did not see the harm. What the substrate did do — required by the v0.12 schema — is record the observer's coverage declaration: the channels it watches and, equally importantly, the channels it does not. A reviewer reading the `CONSISTENT` result also sees that the observer did not watch the channel the attack used. The harm is not silently missed; it is recorded as unobserved.

Tool-result poisoning. An agent honestly relays a falsified tool response. The agent's claim describes the action correctly. The observer corroborates the action mechanically. The Claim-Check Delta is `CONSISTENT`. And the action is wrong, because the tool the agent queried had been compromised upstream. The substrate is doing the right thing by being consistent — the inconsistency is not in the agent's representation of its action but in the world the agent is reading from. The detection of tool-result poisoning requires defenses outside TAO's scope: tool-integrity monitoring, supply-chain attestation, anomaly detection on tool-response distributions. What TAO's forensic record does provide is localization — the audit trail shows the tool call, the response signature, and the timestamp, narrowing the investigation to the upstream compromise.

Multi-step laundering across individually acceptable actions. Each of three actions passes the substrate: a read of a customer list, a transformation into "aggregated marketing buckets," a disclosure of the aggregate to a marketing warehouse. Every claim resolves; every Claim-Check Delta returns `CONSISTENT`. But the aggregation is small enough that, joined against the marketing warehouse's existing data, it is re-identifying. The deployment policy that prohibits joining customer-list data with marketing data has been violated by the *combination* of three individually

acceptable actions. Pairwise comparison cannot detect this. Episode-level analysis — sliding-window correlation, re-identification heuristics, capability-composition policy — is an explicit non-goal of TAO v0.x and is named as a question for future work in §7.

The point of these limits scenarios is not to say TAO is inadequate. The point is that any honest substrate names its boundary. A reviewer who reads only the catches without the limits gets a misleading picture; a reviewer who reads both can calibrate.

7. Open questions

The substrate raises several questions that sit squarely in regulatory-theory and AI-governance research territory, and that this paper does not attempt to answer.

On safe-harbor design. If a regulator chose to recognize TAO-Attested conformance as evidence in supervisory determinations, what shape would that take? A blanket safe harbor risks regulatory capture — operators optimize their adapters to produce clean signals, and the substrate becomes a checkbox. A no-credit-at-all stance loses the incentive that drives adoption. The middle path (rebuttable presumption, partial credit, mitigating factor) is the live design question.

On evidentiary sufficiency. A TAO tuple is structured evidence about what an agent did. The leap from “we have a structured record” to “this record is admissible in an enforcement proceeding” requires answers to chain-of-custody, authentication, and reliability questions that the substrate does not address.

On cross-jurisdictional records. A deployment running in multiple jurisdictions produces records relevant to multiple regulators. Whose records are they? Under whose authority must they be produced? The parallel debates in cross-border financial regulation and data-protection enforcement are directly relevant.

On the taxonomy of teleological mismatch. The five classes (DIRECT_CONTRADICTION, MISSING_BENEFICIARY, UNACKNOWLEDGED_HARM, AUTHORITY_GOAL_MISMATCH, INSUFFICIENT_INFORMATION) are an empirical guess at the useful slicing of representation-vs-effect divergence. They are not derived from a normative theory. Whether the taxonomy maps cleanly to existing enforcement categories — fraud, negligence, ultra vires, fiduciary breach — is an open question.

On episode-level analysis. Pairwise Claim-Check Delta is the v0.x contract. Future versions of the substrate may define episode-level analysis to address the multi-step-laundering limit. The shape of that extension — sliding-window CCD, capability-composition policy in Mission Profiles, post-hoc audit-log analysis — is research, not promised feature work.

On vocabulary coverage. The 29-verb taxonomy and 9-effect kernel are deliberately small. Whether they cover the consequential surface of agentic AI behavior across domains, or whether they leak in classes the spec has not yet identified, is an empirical question that requires real deployments emitting real tuples.

8. How to engage

The substrate is in working-draft state. The repository at github.com/jperdomo88/tao contains the full specification (~18 RFC-style pages), the JSON schemas, the reference validator in Python, 22 conformance test vectors, eight worked scenarios with three limits exhibits, seven Mission Profile starting points across domains, and stakeholder one-pagers for six audiences.

The most useful contributions, in roughly increasing depth:

1. **Critique of this paper’s framing.** Where the regulatory-theory positioning is overstated. Where the worked examples elide difficulty. Where the limits exhibits don’t go far enough.
2. **Critique of the taxonomy.** Verbs that should not be in the vocabulary, verbs that are missing, effects that the kernel should distinguish but doesn’t, teleological classes that conflate distinct phenomena.
3. **Empirical engagement.** Real deployments emitting real tuples. Instrumenting an agent — even a small one — and producing audit-log data that the substrate’s analytical methods can be sharpened against.
4. **Adversarial scenarios.** Patterns where the substrate produces a `CONSISTENT` result but the action is wrong. The limits exhibits identify three classes; there are almost certainly more.

Hard critique is more valuable than supportive engagement. The author is an outside systems builder; the substrate has matured significantly through prior rounds of external review and is sharper for it. The objections most useful at this stage are the ones a senior reader sees in the first hour that the author has missed after months in the work.

References

- Ayres, I. & Braithwaite, J. (1992). *Responsive Regulation: Transcending the Deregulation Debate*. Oxford University Press.
- Coglianesi, C. & Lazer, D. (2003). “Management-Based Regulation: Prescribing Private Management to Achieve Public Goals.” *Law & Society Review* 37(4): 691–730.

Coglianese, C. (recent work). On management-based approaches to AI risk regulation.

Hood, C. (1983). *The Tools of Government*. Macmillan.

Power, M. (1997). *The Audit Society: Rituals of Verification*. Oxford University Press.

Rudin, C. (2019). “Stop Explaining Black Box Machine Learning Models for High Stakes Decisions and Use Interpretable Models Instead.” *Nature Machine Intelligence* 1: 206–215.

Selbst, A. & Barocas, S. (2018). “The Intuitive Appeal of Explainable Machines.” *Fordham Law Review* 87: 1085–1139.

European Union (2024). *Regulation on Artificial Intelligence (EU AI Act)*. Articles 12 (logging), 14 (human oversight).

National Institute of Standards and Technology (2023). *AI Risk Management Framework 1.0*. NIST AI 100-1.

International Organization for Standardization (2023). *ISO/IEC 42001:2023 — Information technology — Artificial intelligence — Management system*.

This paper introduces TAO and is itself in working draft state. The author welcomes critique, corrections, and adversarial review at jorgeperdomo@gmail.com. The full specification, reference implementation, and worked-scenarios catalog are at github.com/jperdomo88/tao.